LABORATUVAR 5 · GENEL SÜRÜM · Şişeleme Hattı

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad İlayda Şenocak | Grup Sabah B | Tarih 10/28/2026

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)
   Üç şarta bakarım. Component X 2.4 SBOM'da var mı (PLC firmware'inde kullanılıyor mu)? 2.4 sürümü CVE'nin etkilenen aralığında mı? Zafiyetli kısma ağdan ya da uzak erişimden ulaşılabiliyor mu? Üçü de evetse etkiler. Biri hayırsa acil değildir, izlemeye alınır.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?
   Hayır. Önce üç şart doğrulanır, çünkü plansız durdurma ve plansız yama da risk yaratır. Yama, planlı bakım penceresinde uygulanır. Sömürüldüğüne dair belirti varsa makine ağdan izole edilir ve gerekirse durdurulur.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?
   Önce test. Üretim dışında bir test ortamında, yedek PLC ya da simülasyonda denenir. Sonra yedek ve geri dönüş planıyla bakım penceresinde uygulanır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?
   Etkileyebilir, çünkü PLC firmware'i safety fonksiyonunun çalıştığı yapıya dokunur. Üreticinin yama notlarına bakarım: safety bileşeni, sertifika ya da checksum değişiyor mu? Yamadan sonra E-stop, ışık perdesi ve STO tepki süresi yeniden test edilir.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?
   Ağ segmentasyonu ve firewall ile erişimi kısıtlarım, uzak erişimi kapatırım ya da yalnızca jump server ve MFA ile açarım. İzinli cihaz ve protokol listesi uygularım, trafiği izleyip yetkisiz değişiklikte alarm kurarım. Bakım laptopları ve fiziksel erişimi de denetim altına alırım.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.